

Основы кибербезопасности

Вводная карта темы: что защищаем, кто и как атакует, какие меры работают и что означают ходовые термины. Для подробностей по разработке есть отдельная шпаргалка по кибербезопасности.

Что защищаем

- **Конфиденциальность** — данные видит только тот, кому положено.
- **Целостность** — данные не изменены незаметно.
- **Доступность** — система работает, когда нужна.
- **Подлинность** — отправитель тот, за кого себя выдаёт.
- **Неотказуемость** — автор действия не может отрицать его.

Кто атакует

- **Массовые злоумышленники** — бьют по площадям: перебор паролей, известные уязвимости, вымогатели.
- **Целевые группы** — изучают жертву, готовят атаку неделями.
- **Внутренний нарушитель** — сотрудник со злым умыслом или по неосторожности.
- **Подрядчики и поставщики** — путь внутрь через доверенную цепочку.
- **Автоматические сканеры** — постоянный фон: любой публичный адрес прощупывают в первые часы.

Типовые атаки

Фишинг	Письмо или сообщение, ведущее на поддельную страницу входа. Самый результативный способ добыть доступ
Вредоносное ПО	Программы-вымогатели, шпионы, майнеры, бэкдоры
Перебор и подстановка паролей	Подбор по словарю и использование утёкших пар «логин — пароль» на других сайтах
Атака посредника	Перехват трафика между сторонами; лечится шифрованием и проверкой сертификатов
Отказ в обслуживании	Исчерпание ресурсов, чтобы сервис перестал отвечать
Внедрение кода и запросов	Данные пользователя попадают в SQL, команды оболочки или разметку страницы
Социальная инженерия	Давление срочностью и авторитетом вместо технических приёмов
Цепочка поставки	Заражение через библиотеку, образ или обновление, которым вы доверяете
Менеджер паролей	Уникальный пароль для каждой службы без запоминания
Длина важнее сложности	Фраза из нескольких слов надёжнее короткого набора символов
Проверка по утечкам	Пароль из известной утечки бесполезен, какой бы сложный он ни был
Второй фактор	Аппаратный ключ или приложение надёжнее кода по SMS
Раздельные учётные записи	Администрирование и повседневная работа — под разными входами
Отзыв доступа	Уход сотрудника и смена подрядчика — повод пересмотреть все выданные права

Меры, которые работают

- **Многофакторная проверка входа** — отсекает подавляющее большинство атак на пароли.
- **Своевременные обновления** — известная уязвимость опаснее неизвестной: для неё уже есть готовый инструмент.
- **Резервные копии с проверкой восстановления** — главный ответ вымогателям; храните копию вне досягаемости рабочей сети.
- **Наименьшие права** — учётная запись и служба получают минимум необходимого.
- **Сегментация сети** — проникновение в один узел не открывает всю инфраструктуру.
- **Шифрование** — в канале и на дисках, включая резервные копии и ноутбуки.
- **Журналы и наблюдение** — атаку нельзя расследовать, если ничего не записывалось.
- **Обучение людей** — распознавание фишинга снижает риск сильнее многих технических мер.

Пароли и доступы

Термины

- **Уязвимость** — слабое место; **эксплойт** — способ им воспользоваться; **патч** — исправление.
- **Нулевой день** — уязвимость, для которой исправления ещё нет.
- **CVE** — единый идентификатор известной уязвимости; **CVSS** — оценка её опасности.
- **Брандмауэр** — фильтрация трафика по правилам.
- **IDS и IPS** — обнаружение и предотвращение вторжений.
- **SIEM** — сбор и корреляция событий безопасности.
- **VPN** — защищённый канал поверх недоверенной сети.
- **Нулевое доверие** — проверять каждый запрос, а не полагаться на «внутреннюю» сеть.
- **Пентест** — проверка защищённости по договору и в согласованных границах.

Если инцидент случился

1. Не паниковать и не стирать следы
Журналы и образы дисков понадобятся для разбора
2. Изолировать
Отключить затронутое от сети, но не выключать наспех
3. Сменить доступы
Пароли, ключи, маркеры — всё, что могло утечь
4. Оценить охват
Какие данные и системы затронуты, за какой период
5. Уведомить
Руководство, пользователей, при необходимости регулятора — сроки часто ограничены законом
6. Разобрать без поиска виноватых
Что позволило случиться и какие изменения в процессе это исключат

Минимум для небольшой команды

- Второй фактор на почте, в системе контроля версий и у облачного провайдера.
- Менеджер паролей с общим хранилищем для командных секретов.
- Автоматические обновления и регулярная проверка зависимостей.
- Резервные копии по расписанию и учения по восстановлению раз в квартал.
- Список того, что открыто наружу, и регулярная сверка с ним.
- Написанный план действий при инциденте: кому звонить и что делать в первый час.